

Version

2026-05-v11 (enterprise edition)

Last updated

09 June 2026

Last reviewed

7 May 2026 (next review due 7 May 2027)

Reading time

~27 min · or read the 30-second summary below

Structure

Part 1 - who we are. Part 2 - what each app module does with your data (six sections, one per module). Part 3 - cross-cutting compliance (transfers, retention, security, your rights).

In 30 seconds

- We collect what we need to run your account, your bookings and your events - nothing else.
- **We don't run analytics, advertising or behavioural tracking.** No Google Analytics, no Vercel Analytics, no Meta Pixel.
- **We never sell your data.** Sub-processors (Stripe, Supabase, Resend, Twilio, Cloudflare, Cookiebot, Google Maps) only receive what they need to do their job.
- **Your card is held by Stripe**, never by us. We see booking records, not card numbers.
- **Maps load only after you accept Functional cookies.** Decline → static placeholder.
- **Self-service rights:** export your data and delete your account from your profile.

App module → Policy section

Part 2 below maps one-to-one to the modules of the Service. If you want to know what a particular feature does with your data, jump straight to the corresponding section.

APP MODULE	POLICY SECTION	LEGAL PURPOSE
1. Identity & Profile	§4 Account Registration & Data We Collect	Discloses exactly what profile info is collected, who has access, and how it is secured.
2. Directory Engine	§5 Public Profiles & Marketplace Disclosures	Clarifies what posted on public event pages or teacher directories is visible to everyone.

3. Ticketing & Transfers	<u>§6 Financial Transactions & Secure Transfers</u>	Discloses that payment data is handled by Stripe, and explains data shared during ticket transfers.
4. Maps & Geolocation	<u>§7 Location Services & Geolocation</u>	Confirms GPS is read client-side only on user action; we never track location in the background.
5. Referrals	<u>§8 Referral Programs & Peer-to-Peer Invites</u>	PECR / anti-spam: users must have permission before entering a friend's email.
6. Communications	<u>§9 Transactional Emails & Your Rights (GDPR)</u>	How users opt out of marketing, request deletion, and how we retain financial data for tax law.

CONTENTS

Part 1 - Who we are

1. [About this Policy](#)
2. [Who we are \(legal entity, DPO, EU representative\)](#)
3. [Applicable laws](#)
4. [What we do NOT do with your data \(AI, analytics, A/B tests\)](#)

Part 2 - What each module does with your data

1. [Account Registration & Data We Collect \(Identity & Profile\)](#)
2. [Public Profiles & Marketplace Disclosures \(Directory Engine\)](#)
3. [Financial Transactions & Secure Transfers \(Ticketing & Transfers\)](#)
4. [Location Services & Geolocation \(Maps & Geolocation\)](#)
5. [Referral Programs & Peer-to-Peer Invites \(Referrals\)](#)
6. [Transactional Emails & Your Rights \(GDPR\) \(Communications\)](#)

Part 3 - Cross-cutting compliance

1. [Lawful basis matrix](#)
2. [Information sharing & sub-processors](#)
3. [International transfers](#)
4. [Data retention](#)
5. [Data security](#)
6. [Data breach notification](#)
7. [Cookies and tracking](#)
8. [Subject Access Request process](#)
9. [DPIA & ROPA](#)
10. [Children](#)

11. Accessibility
12. Automated decisions & profiling
13. Third-party links
14. Changes to this Policy
15. Governing law
16. Contact & complaints
17. Sanctions, appeals & complaints SLA
18. Version history

PART 1 - WHO WE ARE

1. About this Policy

Inteleforge Limited, trading as **The SBK Dance** ("we," "our," "us"), is the data controller responsible for your personal data. This Privacy Policy explains how we collect, use, disclose and safeguard your information when you use our dance-event management platform, website and related services (collectively, the "Service").

This is the **enterprise edition** of the Policy: Part 2 is organised by app module so the disclosures map one-to-one to features of the Service that you can verify for yourself in the public source code.

2. Who we are (legal entity, DPO, EU representative)

Companies Act 2006 §82 disclosure. *Inteleforge Limited (England & Wales). Company number and registered office details are pending publication; they will appear here once configured. (Production builds cannot ship without them.)*

Data Protection Officer (DPO). We have not appointed a DPO. Our processing does not meet the threshold conditions in Article 37 UK GDPR. Privacy questions are handled by our Privacy & Compliance

Officer at support@dancerealm.co

Territorial scope. The Service is operated from the United Kingdom and is available globally. The controller is established in the UK and is registered with the UK Information Commissioner's Office; UK data-protection law (UK GDPR + Data Protection Act 2018) governs the controller's processing. Where users are located outside the UK, additional national privacy laws may also apply to that user's personal data (for example, EU/EEA GDPR for users in the European Economic Area, CCPA/CPRA for users in California, LGPD for users in Brazil, DPDP Act for users in India). We rely on the rights and protections in those laws in addition to UK GDPR; users may exercise their statutory rights directly with the controller using the contact details above. Users are responsible for ensuring that their use of the Service complies with any laws applicable to them locally.

3. Applicable laws

We process your personal data in accordance with:

- the UK Data (Use and Access) Act 2026 (the "2026 Act");
- the UK General Data Protection Regulation (UK GDPR);
- the Data Protection Act 2018;
- the Privacy and Electronic Communications Regulations 2003 (PECR);
- the Consumer Rights Act 2015 and the Consumer Contracts Regulations 2013 (where you transact with us as a consumer);

- the Equality Act 2010 (accessibility, see §20);
- HMRC and Companies Act 2006 record-keeping rules (financial retention, see §13).

3a. What we do NOT do with your data

Some of the most important commitments we can make are about what your data is *not* used for. The paragraphs below apply across every app module described in Part 2.

3a.1 No AI / machine-learning training

We do not use your personal data to train any artificial- intelligence or machine-learning model - neither our own nor anyone else's. Specifically:

- Account information (email, name, phone, role) is never used as AI training data.
- User-generated content (events, reviews, profile bios, photos) is never fed into LLM training datasets or generative-AI fine-tuning runs.
- Booking, payment and activity records (RSVPs, follows, saves) are never sold or shared with data brokers for training purposes.
- Our sub-processors (named in §11) are contractually prohibited under our Article 28 processing agreements from using the data they receive to train their own AI products beyond the specific service they perform for us.

If we ever introduce an AI- or ML-powered feature that would require this position to change, we will (a) publish a new version of this Policy describing the feature, the data involved, the lawful basis, and the third-party model; (b) obtain explicit opt-in consent from you *before* any of your data is used; and (c) continue to honour your right to object (Art. 21) and your right not to be subject to solely-automated decisions (Art. 22). The only automated risk-scoring on the Service today is Stripe Radar (see §6.5 / §21), processed by Stripe under their own Article 28 terms; we do not contribute training data.

3a.2 No third-party analytics, advertising or behavioural tracking

We do not run Google Analytics, Vercel Analytics, Hotjar, Mixpanel, Amplitude, PostHog, Meta Pixel or any equivalent tool. We do not perform automated profiling that has legal effects on you. We do not show advertising on the Service.

3a.3 Anonymised & aggregate statistics

We compute and publish aggregate statistics about the Service (total event count, total user count, total bookings since launch) on the homepage and at the public endpoint </api/stats>. These figures are anonymised before publication: the aggregation step strips every personal identifier and the published numbers are pure counts that cannot be linked back to an individual.

Under UK GDPR Recital 26, truly anonymised data falls outside the scope of data-protection law. Even so, we disclose the practice here for transparency. We do not publish per-organisier, per-region or per-time-window breakdowns that could re-identify users at scale.

3a.4 No A/B testing or feature experiments on production users

We do not currently run A/B tests, feature flags or experimental rollouts that segment production users into differential-experience cohorts *affecting substantive functionality* (i.e. you and another user, on the same plan, see the

same booking flow, the same pricing, the same Pro unlocks, the same Maps gate). Every product feature you see is the same feature every other user sees, with the disclosed exceptions of (a) role-based UI (Teacher vs. Attendee), (b) Pro subscriber unlocks, and (c) admin-only tools.

We may from time to time test wording variations on marketing emails, transactional email subject lines, or static-content layouts that do not affect the data we collect or the contractual experience - these marketing-optimisation tests are common across the web and do not segment users by personal data. If we begin A/B testing of substantive features, we will document the lawful basis, the data collected per-cohort and the opt-out path before running any experiment. We will not retroactively enrol existing users in a cohort without notice.

PART 2 - WHAT EACH APP MODULE DOES WITH YOUR DATA

4. Account Registration & Data We Collect(Module: Identity & Profile)

What this section discloses. Exactly what profile information we collect when you sign up or update your account, who can see each field, and the technical measures protecting it.

4.1 What we collect at signup

- Email address (primary identifier).
- Password - never stored in plain text. Hashed using bcrypt at cost factor 10.
- OR Google OAuth profile data (name, email, profile picture) if you sign up with Google.
- Display name.
- Account role (Attendee / Teacher / Organizer / Admin) - chosen at signup.
- Phone number - required for Teacher/Organizer accounts; optional for Attendees. Verified via SMS OTP through Twilio.
- Marketing-consent flag - opt-in only at signup; off by default.
- Optional referral code (see §8).

4.2 What you can add later

- Avatar / profile photo.
- Bio (Teachers/Organizers only - see §5 for visibility).
- Dance styles, location, social-media links (Teachers/Organizers).
- Saved events, RSVP history, follow relationships.
- Reviews and 1–5 star ratings of events you attended.

4.3 Visibility matrix

FIELD	VISIBLE TO YOU	VISIBLE TO ORGANISERS (EVENTS YOU ATTEND)	PUBLIC	INTERNAL ADMINS
Email	✓	✓ (if you book)	✗	✓

Phone	✓	✗	✗	✓
Display name	✓	✓	✓ (if review left)	✓
Avatar	✓	✓	✓	✓
Password hash	✗	✗	✗	✗ (never inspected)
RSVPs	✓	✓ (their own events)	✗ (counts only, not names)	✓
Saved events	✓	✗	✗	✓

4.4 Technical safeguards

- **Session tokens** (sb-access-token, sb-refresh-token) are stored in HttpOnly & Secure cookies - JavaScript on the page cannot read them, eliminating the most common XSS-based account-takeover vector.
- **Passwords** are hashed by Supabase Auth (the platform manages the bcrypt cost - currently 10 minimum; under a constant industry uplift programme). Plaintext is held only briefly during the request that authenticates you, then discarded. We never log plaintext passwords or the hashes themselves at any layer of our stack - verified by the redaction rules in src/lib/log-scrub.ts.
- **CSRF protection:** every state-changing request requires a double-submit token (csrf-token cookie + x-csrf-token header).
- **Database access** is restricted by Supabase Row-Level Security (RLS) policies - your row is only readable by the holder of your JWT.
- **Audit logs** capture authentication events (sign-in method, IP, user agent, timestamp). Retained 12 months (see §13). Available to you on subject access request (§17).
- **Rate limiting** on signup and login endpoints to prevent credential stuffing.

Security features not yet shipped (on our roadmap). The following industry-typical protections are *not currently available* on the Service. We disclose them here so you can make an informed choice and so a regulator can see we're aware of the gap:

- **Multi-factor authentication for non-admin users.** Admin accounts are MFA-protected (§4.6 R9). Regular Attendee / Teacher / Organizer accounts are not yet offered TOTP or passkey enrolment. Roadmap: 2026.
- **New-device / new-country sign-in alerts.** Industry leaders (Monzo, Stripe) email or SMS users when a sign-in originates from an unusual location or device. We do not currently send such alerts. Until we do, the best mitigation available to you is to use a strong unique password (we check against the HIBP breach list), and to

contact support@dancerealm.co immediately if you suspect compromise.

4.5 Lawful basis

Account creation, authentication and profile management are processed on the basis of **contract performance** (Article 6(1)(b) UK GDPR) - without these data we cannot provide the Service you asked for. Phone-number verification is also contract performance. Marketing-consent flag is processed on the basis of your **consent** (Article 6(1)(a)).

4.6 Module risk register & mitigations

We publish below the full identity-and-account threat surface the Service has been designed against, with the mitigation in place for each. This is unusually transparent for a privacy notice - most operators keep this in an internal DPIA - but we believe it is the clearest way to show users (and any regulator reviewing this Policy) that our Article 32 UK GDPR "appropriate technical and organisational measures" are concrete, not slogans. The same register, with internal-risk scoring, is maintained as part of our DPIA (see §18).

A. Account & authentication threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
------	-----------------------	---------------------

Credential exposure & account takeover	An attacker steals your password through phishing, breach reuse, or guessing.	Your password is hashed by our authentication provider Supabase (industry-standard bcrypt at the platform-managed cost factor - Supabase publishes their crypto choices in their security documentation). During the email-verification window we additionally hold a transient bcrypt-hashed copy at cost factor 12 to detect tampering attempts on the verification email. We never store plaintext passwords, and we check against the Have-I-Been-Pwned breach list at signup and password change. Authentication endpoints are rate-limited at the edge (e.g. password-reset capped at 3 attempts per minute per IP; admin MFA verify capped at 5 attempts per 15 minutes per account); exact limits per surface are tuned operationally.
--	---	--

Privilege escalation (Student → Organizer / Admin)	A standard account tries to gain Teacher or Admin privileges by manipulating client-side requests.	Role is enforced server-side on every privileged endpoint via requireOrganizer() / requireAdmin() guards; the client-side role hint is non-authoritative. Database row-level security (RLS) on Supabase rejects mismatched role queries even if the API layer is bypassed.
Session hijacking via unsecured token storage	An attacker steals your auth token from a compromised browser extension or XSS payload.	Auth tokens (sb-access-token, sb-refresh-token) are HttpOnly + Secure cookies - JavaScript on the page cannot read them. Content Security Policy restricts script sources. Supabase rotates the refresh token on every successful refresh.
Unencrypted cookie exploitation via XSS	An attacker injects script into a page and exfiltrates session cookies.	All session cookies are HttpOnly. CSP script-src blocks inline and unknown-origin scripts. React JSX automatically escapes all interpolated strings; we never use dangerouslySetInnerHTML with user-supplied content.

Brute-force auth flooding	An attacker tries thousands of login or password-reset attempts per minute.	Edge-level rate limiting in src/middleware.ts + Upstash Redis-backed authoritative rate limiter on every auth endpoint (/api/auth/signup, /login, /api/auth/forgot). Failed attempts also trigger Cloudflare bot challenge.
CSRF on password change / account deletion	A malicious site tricks your browser into submitting a destructive request to your account.	Double-submit CSRF token on every state-changing request. The csrf-token cookie value must match the x-csrf-token header; mismatched requests are rejected at the middleware layer before the route handler runs.
Unauthorised account recovery via email spoofing	An attacker spoofs your email address and triggers a password-reset email to gain access.	Password resets always go to the registered email of record. We require the user to click a link AND enter a fresh OTP delivered to that email. Password-reset emails carry SPF/DKIM/DMARC alignment so spoofed senders are rejected by mail providers before delivery.

OAuth state-parameter tampering	An attacker hijacks a Google sign-in flow by replaying a captured authorisation code.	Supabase Auth issues a per-flow state parameter and validates it on the callback. Mismatch terminates the flow.
MFA / OTP bypass on admin profiles	An attacker who has stolen an admin password tries to bypass the second-factor check.	Admin MFA is enforced server-side after every successful password authentication. Bypass is impossible via the API: the <code>/api/auth/admin-mfa/verify</code> route is the only path that issues an admin-scoped session token.
Spam / bot registration attacks	Automated bots create thousands of fake accounts to abuse the referral programme or platform credits.	Supabase Auth bot challenge (hCaptcha) at signup, plus our own bot-detection layer (<code>src/lib/bot-detection.ts</code>) running honeypot fields, time-on-form heuristics and IP-reputation lookup against known abuse lists. Suspicious accounts are flagged for manual review.
Arbitrary admin sign-up bypass	An attacker tries to create an admin-role account directly via the API.	The <code>/api/auth/signup</code> handler hard-codes the issued role to <code>ATTENDEE / ORGANIZER / TEACHER</code> . Admin role can only be granted by an existing admin via <code>/api/admin/users/[id]/role</code> , which itself requires an authenticated admin session + MFA.

Sensitive PII in logs	Passwords or auth tokens leak into server logs through accidental console.log calls.	Log redaction in our logger utility strips known sensitive keys. Code review checklist explicitly forbids logging request bodies on auth routes. Log retention is 12 months rolling, then deleted.
-----------------------	--	--

Simultaneous-device session overuse	A single account is active on dozens of devices, suggesting compromise or sharing.	Refresh-token rotation invalidates older tokens on use, and our authentication provider (Supabase) revokes the entire session family if it detects an already-rotated refresh token being presented (the OAuth 2.1 / RFC 6749bis recommended behaviour). Stripe Radar flags subscription-paying accounts active from too many distinct IPs. A self-service "list and revoke all my active sessions" UI is on our outstanding-mitigations list; today, the equivalent is to click <i>Logout</i> from any signed-in tab (which invalidates the current refresh token everywhere it is presented) followed by a password change (which Supabase responds to by incrementing the user session-version, invalidating every existing refresh token).
-------------------------------------	--	--

Multi-tab role-clashing	A user with both Attendee and Teacher tabs open ends up with inconsistent role state.	Role is read fresh server-side on every authenticated request from the database, not from a stale tab cache. Client UI is purely a render hint - the authoritative role on the JWT is checked at every API boundary.
-------------------------	---	--

B. Subscriptions, billing & Stripe-integration threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
Unconsented third-party data sharing (Stripe sync)	Your name / email is silently shared with Stripe before you have given consent.	Stripe is named as a sub-processor in §11 with the data shared explicitly listed. Your data only reaches Stripe when you initiate a payment or subscription; we do not pre-create Stripe customers in advance.
Billing dispute / chargeback liability (AutoPay)	AutoPay is enabled on your account without your clear authorisation, leading to disputed charges.	AutoPay is opt-in only, off by default, and revocable from your profile. We record the timestamp, IP and consent-text version when you enable it (PSD2 audit requirement). Disabled instantly when you toggle off.

Stripe webhook sync delay (access lag or double billing)	Your subscription status takes minutes to update on our side, leaving you locked out or charged twice.	Webhooks are idempotent (deduplicated by Stripe event ID). The Subscription Realtime Listener supplements webhooks with Supabase Realtime so the UI updates within seconds. <code>/api/subscription/</code> me consults Stripe directly as a fall-through if our cache is stale.
Unnotified subscription plan / price modifications	We change the price you pay without telling you.	Price changes apply to renewals only, never to mid-period billing. Material changes trigger an in-app notice and email at least 30 days before effective date, and we offer a refund or alternative where consumer law requires it (Terms §17).
Orphaned Stripe customers (DB record deleted, Stripe still active)	Your local account is deleted but a Stripe Customer remains, potentially still being billed.	The account-deletion job at <code>/api/cron/purge-deleted-accounts</code> calls the Stripe Customer-delete API as part of its termination sequence. Active Subscriptions are explicitly cancelled before deletion. Reconciliation report runs weekly.

Zombie subscriptions (active billing on deleted accounts)	A deleted account is still being billed monthly because the cancellation step failed.	Same mitigation as above plus a daily reconciliation job that scans active Stripe Subscriptions against active local accounts and alerts on any mismatch. Any zombie billing is refunded automatically when detected.
Incomplete subscription cancellation (charged after click)	You click "Cancel", the API times out, and you're billed again at renewal.	Cancel is idempotent: the request is safely retryable and the second click cannot be charged. We display the cancel-effective date immediately on the next page render; if you don't see "Cancels on ..." within 10 seconds, contact support.
Stripe API version mismatch (sudden webhook failure)	Stripe upgrades their API and our webhook handler stops parsing events, leaving your subscription in limbo.	Our Stripe library is version-pinned; we explicitly opt into a fixed Stripe API version via the apiVersion SDK option. Stripe's own backwards-compatibility policy keeps webhook payloads stable for 24 months; we test before any pinned upgrade.

Orphaned Stripe webhooks (event with no matching DB user)	A Stripe webhook fires referencing a Customer ID we have no record of.	Webhook handler logs the event, stores the orphaned payload in a dead-letter queue, and pages on-call. Most common cause is a dev-environment Stripe key being used in a production webhook by mistake; the handler refuses to process events not signed with the production webhook secret.
Stripe disconnect loophole (revoked permission, still active locally)	A Teacher disconnects Stripe Connect but their events keep accepting bookings.	Stripe Connect account.application.deauthorized webhook triggers automatic suspension of all active Events for that organiser and prevents new bookings. Existing bookings honoured to the original payment method until refunded.
Failed payout routing (incorrect Stripe Connect setup)	An organiser's ticket revenue fails to reach their bank account.	Stripe Connect onboarding is mandatory before an Organizer can publish a paid event. Payout failures surface in the organiser dashboard and trigger an email + SMS alert. Funds remain in the platform account until resolved.

Subscription price tampering	An attacker modifies the HTML form to send a £0 price for a £4 plan.	Price is read server-side from Stripe Price IDs by ID lookup at checkout - the client never controls the amount. Tampered requests are rejected.
Card-testing attacks	Bots use our Stripe signup flow to test thousands of stolen cards.	Stripe Radar with custom rules: hard-block on velocity (more than N attempts per IP / fingerprint within a window), CVC mismatch, mismatched billing geography. hCaptcha challenge before checkout for unauthenticated paths. The Service does not expose a guest-checkout option that bypasses authentication.
Account-sharing fraud (single subscription, many users)	A subscription is logged in from many distinct IPs / browsers - one paying user, many freeloaders.	Refresh-token rotation forces concurrent sessions to invalidate older tokens. Stripe Radar flags "impossible-travel" logins. Repeated detection results in suspension; we do not currently apply DRM-style hard caps on session count.

C. Data isolation & API protection threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
------	-----------------------	---------------------

Direct database access via weak API route protection	An unauthenticated request hits a route that exposes other users' data.	Every /api/ route validates the session JWT before touching the database. Supabase Row-Level Security (RLS) is the second line of defence: even if a route forgot to check, the DB rejects mismatched-user queries.
SQL injection / parameter tampering on profile fields	A crafted payload in a profile field manipulates a database query.	All database access goes through Prisma ORM with parameterised queries - string interpolation into SQL is impossible. Input validation via Zod schemas at every API boundary; profile fields are stripped of HTML and JS before persistence.
Cross-tenant data exposure (multi-tenant schema leaks)	An attacker queries another organiser's events or attendees by guessing IDs.	RLS enforces per-row authorisation: every query carries the authenticated user's ID, and rows are returned only if the policy allows. Event-organiser queries are gated by <code>organiser_id = auth.uid()</code> ; attendee lists are gated by the requesting user being the event organiser.

D. GDPR & regulatory threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
------	-----------------------	---------------------

GDPR right-to-erasure vs. tax-retention conflict	You ask us to delete all your data, but UK tax law requires us to keep transaction records.	On erasure we anonymise (not delete) financial records: PII fields are stripped, only the financial-event data remains, retained for 7 years per HMRC and Companies Act 2006 - see §13. The anonymised record cannot be reassociated to you. Article 17(3)(e) UK GDPR explicitly permits this trade-off where retention is required by Union or Member State law.
Incomplete age verification (under-13 registration)	A child under 13 registers without verifiable parental consent.	Account creation requires age 16+ (declared at signup). The Service is not directed at children under 13 and we delete on notice (§19). Robust age-gate with parental-consent flow for 13–17 is on our DPIA outstanding-mitigations list (see §18).

GDPR parental-consent breach (no age gate)	Children register without their parent / guardian agreeing to our Terms.	Same as above. We do not currently process special-category data, do not run advertising or analytics, and do not profile users - so the heightened risks the AADC targets do not arise. The age-gate feature is being prioritised as the most material outstanding mitigation.
--	--	---

This register is reviewed and refreshed during the DPIA review cycle (annually, or sooner on a new vendor / new processing purpose / material change in UK data law). The internal DPIA carries the same risks with likelihood x severity scoring; this Policy lists only the public-facing mitigation. If you spot a risk we've missed, please email support@dancerealm.co - we want to know.

5. Public Profiles & Marketplace Disclosures(Module: Directory Engine)

What this section discloses. When you create an Event listing, a Teacher profile, or leave a public review, the content becomes part of a public marketplace anyone can read without an account. This is the price of using a discovery platform; we want you to understand it explicitly.

5.1 What becomes public

WHEN YOU DO THIS...	...THIS BECOMES PUBLICLY VIEWABLE
Publish an Event	Title, description, dates, venue address (when applicable), photos, ticket price, organiser display name + avatar
Create a Teacher profile	Bio, dance styles, location, social-media links, public-facing contact email or phone (only fields you mark public)
Leave a review	Star rating (1–5), free-text review, your display name + avatar (NOT your email)
Follow a Teacher	Aggregate follower count visible; identity of individual followers NOT public
RSVP "Going"	Aggregate count visible; your name visible to the organiser only

5.2 Marketplace search indexing

The Service exposes a public search index covering Events and Teacher

profiles so users can discover dance content. Pages with the listing are accessible without signing in and may be indexed by search engines (Google, Bing, etc.). You can edit or unpublish your own listings at any time from / *dashboard*; once unpublished the page is removed from our index, but third-party search-engine caches may retain it for several days. To request faster removal from a specific search engine, use that engine's URL-removal tool - we cannot do this on your behalf.

5.3 Cross-tenant isolation (Organiser A cannot see Organiser B's data)

The Service is multi-tenant: many Teachers and Organizers run their own events on the same platform simultaneously. We make the following architectural promise about isolation between organisers' data:

- **Organiser-scoped data is row-level isolated.** An organiser's events, attendee lists, booking details, payout records and revenue figures are visible only to that organiser, our admins, and the attendee themselves where applicable.
- **One organiser cannot see another organiser's data.** We do not aggregate "all events" or "all attendees" views across organisers outside the public marketplace described in §5.1.
- **Enforcement is at the database layer.** Supabase Row-Level Security policies on every personal- data table check that the requesting user's ID matches the row's owner before returning data. Even if a future API route forgot to filter by user, the database itself rejects mismatched-user queries.
- **Admins can see across tenants for support purposes only.** Admin role grants are tightly held; admin actions against user data are audit-logged and reviewable. Admin MFA is mandatory (see §4.6 R9).

Risk R31 in §4.6 (cross-tenant data exposure) carries the internal mitigation detail.

5.4 Lawful basis

Publishing your own Event or profile is processed on the basis of **contract performance** (Art. 6(1)(b) UK GDPR - you asked us to publish it as part of the discovery service we provide) and your **consent** (Art. 6(1)(a)) for the public-visibility decision itself, which you make actively when clicking "Publish".

5.5 Module risk register & mitigations

The Directory Engine is the most public-facing part of the Service. The risk profile is dominated by content integrity, search-engine cache and inadvertent disclosure of personal data through free-text fields.

A. Public-exposure threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
------	-----------------------	---------------------

Inadvertent doxxing through venue address	A teacher hosting from home publishes their own postcode in an event listing.	Event-creation form warns when the venue address looks residential; we recommend marking the address "visible only to ticket-holders" for home-based events. Pre-event addresses are blurred to non-attendees by default for the "Private home class" category.
PII leakage in free-text reviews	A reviewer mentions another attendee by full name, phone or email in a public review.	Reviewers' own emails are never displayed publicly. Reviews can be reported via a flag link and are then removed pending admin moderation. Server-side log-scrubbing strips email and phone patterns from any logged review content. Automated input-time PII scrubbing on review submission is on our DPIA outstanding-mitigations list.
Public follower / RSVP leak revealing social graphs	Someone scrapes the "Going" counts to infer who attends events with whom.	Aggregate counts are public; individual attendee identities are visible <i>only</i> to the event organiser. Follower / following lists are not public - only counts. RSVP status is private to the user and the organiser.

Right-to-be-forgotten vs. third-party search caches	You delete a public profile but Google still shows it for weeks.	On unpublish we serve noindex headers and a 410 Gone on the canonical URL. We cannot remove third-party caches directly - the policy explains the user's right to use Google's URL-removal tool. We file removal requests on a user's behalf for high-impact cases on written request.
Profile-photo abuse (explicit / unauthorised content)	Someone uploads explicit imagery, an unauthorised celebrity photo, or an offensive logo as a profile picture.	Reporting flow lets any user flag a profile or event image for admin review. Flagged images are hidden pending moderation decision (typically within 5 working days). EXIF metadata stripped on upload. Confirmed violations result in account suspension. Automated NSFW classification is on our DPIA outstanding-mitigations list (§18).

Minor attendee exposure	An organiser posts photos of an event that include attendees under 18 without consent.	Event-photo upload form requires the organiser to confirm they have consent of identifiable subjects (model release). For events flagged as having minors, upload is gated behind an explicit attestation. Image takedown requests are actioned within 5 working days.
Doxx-by-search through location autocomplete	The venue autocomplete suggests a precise residential address based on partial input, exposing more than the user intended.	We use Google Places Autocomplete in "establishment" bias mode for public venues. Residential pins are de-emphasised in suggestions. The teacher must explicitly confirm a residential venue selection.

B. Content-integrity threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
Fake / impersonator teacher profiles	Someone creates a Teacher profile pretending to be a well-known instructor.	Phone verification is mandatory for the Teacher role. Identity-claim disputes have a takedown procedure documented in our acceptable-use policy: report impersonation to the privacy contact (§25) and we investigate within 5 working days. A formal verified-teacher badge programme is on our DPIA outstanding-mitigations list.

Review manipulation (organiser self-reviewing)	An organiser creates fake accounts to leave 5-star reviews of their own events.	Reviews can be left only by users who hold a confirmed ticket for the event (verified server-side at submission). Organisers cannot review their own events; the review API rejects same-account submissions. Multi-account abuse is detected by Stripe Radar correlation between the reviewing accounts and the organiser's payouts.
Defamatory or harassing reviews	A reviewer leaves false or abusive content about an organiser.	Review text passes through the same moderation classifier as profile images. Organisers can flag reviews via a "Report" link; flagged reviews are hidden pending admin decision. Defamation takedown requests are actioned within 5 working days; we follow the Defamation Act 2013 §5 procedure for clear-cut cases.

Hate speech / discriminatory event criteria	An event title or description contains hateful language, or an event imposes discriminatory entry criteria contrary to the Equality Act 2010.	User reporting flow lets any visitor flag an event for admin review. Confirmed violations result in unpublishing and account suspension. Automated language scanning is on our DPIA outstanding-mitigations list (§18); we currently rely on user reports + manual review.
IP / trademark infringement in event titles	An event uses a brand or trademark without authorisation.	DMCA-style takedown procedure in our acceptable-use policy with a documented contact email for rights-holders. Repeat offenders are suspended.
Spam / SEO-abuse fake events	A non-dance business creates fake events to harvest backlinks for SEO.	Event-creation paywall (configured per category) prices fake-event creation out. New organiser accounts have rate-limited event creation; bulk-publish behaviour triggers manual review.
Image-rights / copyrighted photography	An organiser uses a stock or copyrighted photo without licence.	Upload form requires confirmation of usage rights. DMCA takedown procedure handles formal complaints; repeat offenders are suspended.

C. Search-engine & discovery threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
------	-----------------------	---------------------

Bulk competitor scraping	A competitor harvests our event listings to populate their own platform.	Public listing endpoints are rate-limited per IP. robots.txt permits indexing by recognised search engines but blocks crawler signatures associated with scraping. Cloudflare bot-management heuristics escalate suspicious patterns.
Stale-listing search-engine indexing	An unpublished or expired event still appears in Google search results.	Unpublished event URLs serve a not-found page with strict noindex, nofollow, max-snippet:0 robots metadata so search engines de-list the URL on next crawl. We submit URL-removal requests for events removed for legal reasons. The sitemap regenerates on demand and includes only currently-published events.
Cross-listing fraud (same event re-posted by impostor)	A scammer copies a legitimate event and re-posts it under their own organiser account to capture bookings.	Title + venue + date triple-key fuzzy matching at publish surfaces likely duplicates to admin review. Confirmed fraud results in immediate unpublish and refund of all affected bookings.

6. Financial Transactions & Secure Transfers (Module: Ticketing & Transfers)

What this section discloses. Card data is handled exclusively by **Stripe Payments UK Limited** inside their PCI-DSS Level 1 environment - we never see your full card number, CVC or expiry. Ticket transfers use tokenised, time-limited links so the recipient gets only what they need to claim the ticket.

6.1 What we receive when you pay

DATA	STORED BY US	STORED BY STRIPE
Card number (PAN)	✗ Never	✓ Tokenised
CVC / expiry	✗ Never	✓ Tokenised
Cardholder name	✗ Never	✓
Booking reference, amount, currency, date	✓	✓
Stripe customer ID	✓ (token, not card)	✓
3-D Secure outcome	✓ (boolean)	✓ (full)
Refund record	✓	✓
AutoPay consent metadata (timestamp, IP, consent-text version)	✓ (PSD2 audit requirement)	-

6.2 Stripe Connect for organiser payouts

When a Teacher/Organizer accepts payments for their Events they onboard through Stripe Connect. Stripe collects the organiser's identity verification documents (passport / driving licence) and bank-account details directly - we receive only a Stripe Connect account ID and the high-level verification status (verified / pending / rejected). We never see the verification documents.

6.3 Ticket transfers

You may transfer a confirmed ticket to another person from the booking detail page (where the Event organiser permits transfers). The mechanism:

1. You enter the recipient's email address.
2. We mint an HMAC-signed transfer link, valid for a limited window, and email it to the recipient.
3. The recipient clicks the link → we verify the signature → ownership transfers and a fresh digital ticket is issued in their name.
4. You may cancel the transfer before the recipient claims it; cancellation invalidates the link immediately.

Data shared with the recipient: the original organiser's event detail (already public), your display name (so the recipient can identify the sender), and the ticket. The recipient's email is held only for the duration of the transfer window plus 30 days for audit; if they decline or the link expires, the email is purged.

6.4 AutoPay billing schedule & refund timing

AutoPay billing window. Subscription charges fire on the anniversary of your initial signup - e.g. if you signed up at 14:32 UTC on the 15th of the month, your next renewal attempts on the 15th of the following month, typically between 14:00 and 18:00 UTC depending on Stripe's queue load. The card statement date you see may differ from this by 0–2 days depending on your card network's settlement.

Failed-payment retry window. If a renewal fails (expired card, insufficient funds, soft decline), Stripe Smart Retries attempts up to 4 times across 21

days, with notification emails from us at retry 1 and retry 4. After all retries fail, your subscription is paused; Pro features lock until you update the payment method.

Refund timing. When we issue a refund - whether for a cancelled event, a successful chargeback dispute, or a 14-day statutory withdrawal - the refund fires immediately on our side via Stripe's reverse- payment API. The funds typically appear in your card statement within **5–10 working days**; international cards or some prepaid cards can take up to 14 working days, which is your card network's clearing pipeline (we have no control over it). Apple Pay / Google Pay refunds settle to the underlying card on the same schedule. If your card was closed before the refund arrived, Stripe returns the funds to our balance and we contact you within 5 working days to arrange an alternative payout method.

6.5 Stripe Radar (fraud prevention)

Stripe Radar performs automated risk scoring on every payment attempt. A high-risk score may cause Stripe to require step-up authentication (3-D Secure) or decline the transaction. This is processed on the **Recognised Legitimate Interests** basis introduced by Schedule 4 of the 2026 Act ("detecting, preventing or investigating fraud"). You may ask Stripe to review any decline by their [privacy contact](#).

6.6 Lawful basis

Ticket purchases, refunds and Stripe Connect payouts are processed on the basis of **contract performance** (Art. 6(1)(b)). Fraud prevention is processed on the basis of **Recognised Legitimate Interests** (Schedule 4, 2026 Act). Financial records that we are legally required to keep for HMRC and Companies Act purposes are retained on the basis of **legal obligation** (Art. 6(1)(c)).

6.7 Module risk register & mitigations

Ticketing & Transfers is the highest-financial-impact module. Risks concentrate on payment fraud, ticket-lifecycle integrity, and Stripe Connect organiser onboarding.

A. Payment-fraud threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
Card-not-present fraud	A stolen card is used to buy tickets that the victim later disputes.	Stripe Radar performs real-time risk scoring; high-risk transactions trigger 3-D Secure step-up authentication. Payments outside our normal velocity profile are reviewed before payout to organiser.

Friendly-fraud chargebacks (refund-then-attend)	A buyer attends an event and then opens a chargeback claiming non-receipt.	QR-coded digital tickets are scanned at door (where organisers use the scanning workflow), creating an evidence trail. Stripe chargeback responses include the scan timestamp, IP at booking, and email open / click logs from the confirmation email.
PCI-DSS scope creep through embedded forms	A future change accidentally captures raw card data, putting us into PCI scope.	Stripe Elements is the only path for card entry; the input fields are iframed from <i>js.stripe.com</i> , so card data never touches our origin. Code-review checklist explicitly prohibits non-Elements card-entry components. PCI SAQ-A covers our model.
Currency-manipulation attacks	A buyer changes the form's currency code to pay £10 in Vietnamese dong.	Currency is set server-side by Event configuration, never by client input. Attempted currency override at the API boundary is rejected by Zod schema validation.

Voucher / coupon-code abuse	A discount code intended for a single user is shared and used hundreds of times.	Codes carry max-use, max-uses-per-user, and expiry constraints enforced atomically at redemption (database-level UPDATE with redemption-count check). Single-use codes are deactivated on first redemption.
Quantity-overflow attacks	A buyer attempts to book 999 tickets to drain inventory or exploit a pricing edge case.	Per-event maximum ticket-per-order limit (configurable, default 10). Atomic decrement of available inventory in a single transaction prevents race conditions. Negative-balance attempts rejected at the database constraint level.
Race-condition double-booking	Two simultaneous purchases of the last ticket both succeed.	Inventory decrement uses Postgres row-level locking inside a transaction; the second purchaser is rejected with "Sold out" before payment is captured.
Webhook signature bypass	An attacker forges a Stripe webhook to mark a refund or grant access without payment.	Every Stripe webhook request is verified using stripe.webhooks.constructEvent with the production-only signing secret. Unsigned or mismatched-signature requests are rejected with HTTP 400 before any handler logic runs.

Webhook-replay attacks	An attacker captures a legitimate webhook and replays it to grant duplicate access.	Webhook handler dedupes on Stripe's event-ID inside an idempotency table. A replayed event is recognised and short-circuited.
Stripe API-key compromise	Our Stripe secret key is leaked to GitHub or a log file, allowing fraudulent charges.	Secrets stored in Vercel environment variables only, never in source. Dependabot alerts on accidentally committed credential patterns. Rotation procedure documented; the production webhook secret can be rotated in under 15 minutes.
VAT / cross-border tax mis-application	A non-UK organiser's event charges UK VAT incorrectly, exposing them or us to HMRC liability.	Stripe Tax is enabled for Stripe Connect organisers where applicable. UK-domestic events default to UK VAT rules; cross-border tickets surface a tax-disclaimer to the buyer. Final tax responsibility rests with the organiser per Terms.
Failed-payment retry storms	A user's expired card causes thousands of retry attempts that flood our webhook.	Stripe's Smart Retries cap retries at 4 attempts over 21 days. Our dunning flow surfaces the failure to the user via email and in-app banner; persistent failures pause the subscription, not retry forever.

B. Ticket-lifecycle threats (transfers, refunds)

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
Transfer-link interception	A recipient's email is compromised and an attacker claims the transferred ticket.	Transfer links are HMAC-signed with a 7-day expiry and single-use. The original sender can cancel the transfer until claim, immediately invalidating the link. Ownership change is logged in the booking history visible to both parties.
Ticket scalping	A buyer purchases tickets in bulk and resells them at inflated prices off-platform.	Per-buyer purchase limits configurable per event. Transferred tickets are watermarked with the recipient's name; door scanning shows the named holder. Detected scalping rings forfeit affected tickets and the original buyer is suspended.

Fake-ticket fraud	An attacker forges a ticket QR code to gain entry without paying.	QR codes encode a server-signed booking ID. Scanning verifies the signature and marks the ticket as used; reuse attempts are flagged at the door scanner. If your phone is lost or stolen, contact ssupport@dancerealm.co with your booking reference - we will invalidate the QR and re-issue to a re-verified email. A self-service "lock ticket" control is on our outstanding-mitigations list.
Lost-ticket recovery via email-based fraud	An attacker pretends to be a ticket-holder asking us to reissue.	Re-issuance is self-service from the user's authenticated profile only. We do not reissue tickets via support email without the user being signed in.
Repudiated transfer disputes	After transfer, the original buyer claims the transfer was unauthorised.	Both parties are notified by email at transfer + claim, with full audit trail (timestamps, IPs, the recipient email used). Transfer reversal requires both parties' consent or admin intervention.

Booking-confirmation phishing	An attacker sends fake "your booking is confirmed" emails impersonating us.	All transactional emails are sent from <i>support@dancerealm.co</i> with SPF / DKIM / DMARC alignment configured. Lookalike-domain spoofing is mitigated at the receiving mail-provider layer (Gmail, Outlook). Phishing-report email <i>abuse@thesbkdance.com</i> is monitored by the Privacy & Compliance Officer.
Refund-routing failure	A refund is issued but credited to a closed card or wrong account.	Refunds always go to the original payment method via Stripe's reverse-payment flow. If the card is closed, Stripe returns the funds to our balance and we contact the buyer to arrange an alternative method.

C. Stripe Connect / organiser-onboarding threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
------	-----------------------	---------------------

Organiser-identity fraud	A bad actor onboards as a Teacher with stolen identity documents to receive payouts.	Stripe Connect performs identity verification (KYC) directly - we never see or store the documents. Stripe's anti-money-laundering checks gate payouts. Suspicious patterns (multiple accounts from one device, sudden payout-volume spikes) trigger Stripe-side review.
Bank-account hijack	An organiser's Stripe account is compromised and payouts are redirected.	Bank-detail changes in Stripe require two-factor authentication on the Stripe side. Sensitive changes trigger an email alert to the verified email on file with a 24-hour delay before first payout to a new account.
Payout to suspended organiser	An organiser is suspended for breach of Terms but already has unpaid funds.	Suspension freezes pending payouts. Bookings on suspended organisers' events can be refunded to attendees or held in escrow pending resolution.

Stripe Connect deauth loophole	An organiser disconnects Stripe Connect, leaving open bookings without a payout path.	The account.application.deauthorized webhook triggers automatic suspension of the organiser's active Events and notifies attendees. Existing paid bookings are honoured to the original payment method until refunded or the event proceeds.
--------------------------------	---	--

7. Location Services & Geolocation (Module: Maps & Geolocation)

What this section discloses. We use location data to centre maps on events near you. We **never** read your GPS in the background, and we never load Google's Maps SDK without your consent.

7.1 Two types of location data

TYPE	SOURCE	PRECISION	WHEN TRIGGERED	SENT TO OUR SERVERS?
Approximate region (IP-derived)	Server-side reverse-IP lookup using our own logic; no third-party IP-lookup vendor	City / region	When a map page renders, after Functional consent	Computed server-side; cached client-side for 1 hour as <code>ems_ip_location</code>
Precise GPS	Browser navigator.geolocation - only after you click "Locate me"	Up to ~10 metres	User action only, never automatic	Never sent to us. Read by the Map component client-side and used only to centre the visible viewport. Discarded when the page closes.

7.2 No background tracking

We do not request "background" geolocation permission. We do not use the

Geolocation API while the page is hidden. We do not poll your location. Your GPS is read only in the moment after you click the “Locate me” button on a map; the result is consumed locally to pan the map and is discarded when you navigate away.

7.3 Google Maps SDK is consent-gated

The Google Maps JavaScript SDK is gated behind your Functional cookie consent (see [Cookie Policy](#) §6). Until you accept Functional cookies, every map area on the Service is replaced with a static placeholder. The fallback ensures we cannot leak Google’s personalisation cookies (NID, 1P_JAR, etc.) before you have made a choice.

7.4 Lawful basis

IP-derived approximate region is processed on the basis of **consent** (Art. 6(1) (a)) - it only fires after you accept Functional cookies. Precise GPS is processed on the basis of your active **consent** (the moment-by-moment browser permission prompt).

7.5 Module risk register & mitigations

Location data is the highest-sensitivity category we handle. Risks concentrate on covert tracking, third-party leakage and inference attacks.

A. Location-privacy threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
Covert background GPS	The Service requests your precise location while the page is hidden.	We never call navigator.geolocation on page load or while the page is in a hidden state. Geolocation is requested ONLY synchronously after you click “Locate me”. We do not request the (non-standard) background-geolocation permission. Page Visibility API is only used to pause polling - never to start tracking.

Leakage of GPS to our servers	Your precise GPS coordinates are sent to and logged on our backend.	Browser GPS is consumed in JavaScript only and used to pan the map locally. The coordinates are never sent in any API request body our code emits. We rely on standard web-platform isolation (the Geolocation API, component-local React state) - this is best-effort within the browser's normal security model and does not protect against deliberately installed malicious browser extensions, OS-level forensic memory dumps, or React DevTools running in a profile the user does not control.
Reverse-geocoding leaking home address	A user's precise coordinates are reverse-geocoded server-side, identifying their home.	Reverse-geocoding only happens for an organiser's submitted venue address (a deliberate publish action), never for a user's "Locate me" click. The Maps SDK's reverse-geocoding stays in the browser session.

Pre-consent Maps SDK load	Google's Maps SDK loads (and drops its tracking cookies) before you have given Functional consent.	The useCookieConsent hook gates SDK mount; until you accept Functional cookies, every map area on the Service is replaced with a static placeholder. Verifiable in src/components/maps/MapPlaceholder.tsx.
Cross-device location leak via Google account	A user signed in to Google in another tab has their Maps activity correlated with their Google identity.	This is Google-side behaviour we cannot prevent once Maps is consented to; we disclose it explicitly in §5.3 of the Cookie Policy. Users can either decline Functional consent or sign out of Google before using the Service.
Inference-attack via recurring location patterns	Repeated "near me" queries reveal a user's commute or weekly routine.	We do not store user-specific location-query history. Cached IP-region in localStorage expires after 1 hour and is not sent back to our servers. No per-user location heatmap exists.

Map-tile request leaking visited venues	Each map tile fetched from Google reveals the user's viewport - over time, a list of which venues they viewed.	Tile requests go directly from the browser to Google after consent - the same architecture used by every Google Maps embed on the web. We disclose this in the Cookie Policy and the user can decline Functional cookies to avoid it entirely.
---	--	--

B. Permission & UX threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
Permission-prompt fatigue (dark pattern)	Repeated location prompts wear users down into clicking Allow.	A single prompt is triggered by a single user click on "Locate me". If you decline, we don't re-prompt automatically - you must click again. We do not use the legacy auto-request-on-load pattern that browsers now restrict.
Stale precise-location use	Your GPS reading is held in memory for hours and used to centre the next visit's map.	Precise GPS is read on click and held only in component-local state. It is discarded on navigation. There is no localStorage / sessionStorage write of precise GPS values.

iOS / Android permission divergence	A user on iOS sees different permission language than on Android, leading to inconsistent consent quality.	We rely on the standard W3C Geolocation API; the prompt UX is OS-controlled and consistent within each browser. We do not wrap or replace the native prompt with custom UI that could mislead users.
VPN-induced wrong-region default	A UK user on a VPN sees events near the VPN exit-node city instead of their actual location.	The IP-region default is a starting point only; users can pan the map or click "Locate me" for an accurate centre. We do not block VPN traffic (privacy-respecting) and do not penalise users for using one.

8. Referral Programs & Peer-to-Peer Invites (Module: Referrals)

What this section discloses. The Service includes a peer-to-peer referral programme. The most sensitive aspect of any referral system is anti-spam compliance under the Privacy and Electronic Communications Regulations 2003 (PECR) - sending unsolicited marketing to someone's email is unlawful. We therefore design the referral flow so that **you** are the sender, and a referral can only happen with the recipient's permission.

8.1 How referrals work

1. Every account is automatically issued a unique short Referral Code (e.g. USERMARIA12).
2. You can share that code or the corresponding signup link with people **you have permission to invite** - through your own messaging app, email, social media, or in person.
3. A new user signing up may optionally enter a Referral Code; if valid, we record a one-way link from the new account to your account so any rewards can be attributed.

We do not send referral emails on your behalf. We do not import your address book. We do not auto-suggest contacts. The Service exposes no "Invite friends" feature that mass-mails on your behalf. Any email sent to a third party as part of a referral is sent by you, from your email account, with your full visibility - keeping PECR compliance squarely in your hands.

8.2 Your obligations

By using the Service you confirm that you will only share a Referral Code or signup link with people who have consented to receive that communication

from you, or with whom you have a pre-existing relationship that makes the message expected. Sending unsolicited marketing emails using our links is a breach of these Terms and of PECR (and the equivalent CAN-SPAM, CASL etc. in other jurisdictions). We reserve the right to suspend accounts that we have reasonable grounds to believe are misusing the programme.

8.3 Anti-fraud

Self-referrals, fake-account farming, automated signups and coordinated rings are detected through Stripe Radar signals (see §6.5) and our own heuristics. Detected abuse results in forfeiture of any rewards earned and may result in account suspension.

8.4 Lawful basis

The link between a new account and the referring account is processed on the basis of the new user's **consent** (entering a referral code is an affirmative act, Art. 6(1)(a)) and our **legitimate interest** (Art. 6(1)(f)) in measuring word-of-mouth growth and detecting fraud.

8.5 Module risk register & mitigations

Referrals carry a distinctive risk profile dominated by PECR / anti-spam compliance and reward-system fraud.

A. PECR & anti-spam threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
Mass referral email abuse	A user submits hundreds of friend emails into a "refer-a-friend" form so we mass-email them.	This functionality does not exist on the Service. We deliberately do not provide an "Invite friends by email" feature. Referrals work only by sharing a code or signup link via channels the user controls (their own messaging app, social media, in person).
Address-book scraping	The Service silently uploads the user's contact list to find friends to invite.	We do not request or import contact-list permissions. No contacts API. No contacts.google.com integration. No address-book read on mobile.

Pre-filled referral spam from social-media share	A "Share to Twitter" pre-fill includes a friend's handle, encouraging public unsolicited mentions.	Share buttons pre-fill only the user's own referral code and a generic invitation message - never another user's handle, name or email.
Referral-link spam to harvested addresses	A user runs an automated script that emails referral links to harvested addresses.	Per Terms, this is the user's breach of PECR not ours, but we monitor signup IPs that show coordinated patterns (many signups using the same referral code from disparate addresses with low conversion). Confirmed abuse forfeits rewards and suspends the referring account.
Brand impersonation in referral messages	A user crafts a referral-share message that impersonates us officially.	All public reward terms appear only on our own pages, not in user-crafted share text. We monitor for lookalike-domain abuse via brand-protection alerts and engage takedown procedures with hosting providers.

B. Reward-fraud threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
------	-----------------------	---------------------

Self-referral fraud	A user creates a second account and refers themselves to claim a reward.	Same-IP / same-fingerprint / same-payment-instrument signals correlate suspected self-referrals. Rewards are paid only after the referred account's qualifying action (a paid booking) settles, so self-paying loops are caught at the Stripe Radar layer.
Referral-farm botnets	A coordinated botnet creates thousands of accounts, all using one referrer's code.	hCaptcha at signup. Signup velocity per IP and per referrer code rate-limited. Suspicious cohorts (low retention, high churn within 48 hours) flagged for manual review and reward forfeiture.
Referral hierarchy / MLM-style schemes	A user tries to construct a multi-level marketing scheme on top of our single-level referral programme.	Our referral programme is single-level by design - a referrer earns from their direct referrals only, never from second-degree referrals. Account-deletion and re-creation cycles to chain rewards are detected by device fingerprinting.

Reward-token replay	A reward credit is redeemed, then the user reverses the original referral and redeems again.	Rewards are issued atomically with the referred account's qualifying action. Reversal of the action invalidates the pending reward in the same transaction. Already-redeemed rewards cannot be re-issued.
Prize-qualification gaming	A user manipulates qualifying-action timing or amounts to maximise reward.	Qualifying actions are deterministically defined and verified server-side at the moment of reward issuance - not retroactively. Rules cannot be re-played by changing client-side state.

9. Transactional Emails & Your Rights (GDPR)(Module: Communications)

What this section discloses. Two categories of communication leave our system: (a) transactional notifications you cannot opt out of without ending the underlying contract, and (b) marketing messages that require explicit opt-in and that you can withdraw at any time. Plus your full bundle of UK GDPR rights and how to exercise them.

9.1 Transactional vs marketing

TYPE	EXAMPLES	LAWFUL BASIS	CAN YOU OPT OUT?
Transactional / operational	Signup confirmation, password reset, booking receipt, RSVP reminders, ticket transfer, refund confirmation, security alert	Contract - Art. 6(1)(b)	Only by closing the related ticket / account

Marketing	Newsletter, recommendations, partner offers	Consent - Art. 6(1)(a) + PECR reg. 22	Yes, anytime - see §9.2
SMS - phone verification	OTP code at signup / login	Contract - Art. 6(1)(b)	Required if you have a Teacher/Organizer account

9.2 How to opt out of marketing

- Click *Unsubscribe* in the footer of any marketing email.
- Toggle off *Marketing communications* in your profile settings.
- Email support@dancerealm.co and we will action within 5 working days.

Withdrawal does not affect the lawfulness of any messages we sent before you withdrew consent.

9.3 Your rights under UK GDPR

- **Access (Art. 15):** request a copy of all data we hold about you.
- **Rectification (Art. 16):** request correction of inaccurate data.
- **Erasure (Art. 17):** request deletion (the "right to be forgotten").
- **Restriction (Art. 18):** ask us to limit how we use your data while a dispute is investigated.
- **Portability (Art. 20):** receive your data in a portable JSON format - self-service via your profile settings.
- **Object (Art. 21):** object to processing based on legitimate interests, including any direct marketing.
- **Withdraw consent (Art. 7(3)):** instantly, for any consent-based processing.
- **Not be subject to automated decision-making (Art. 22):** see §21 - we do not currently make decisions affecting you by automated means alone.

9.4 Account deletion + financial-record retention

You can delete your account at any time from your profile. On deletion we anonymise your profile, cancel any active Subscription and outstanding ticket transfers, and place the account in a 30-day grace period during which support staff can recover it on your request. After 30 days the account row is hard-deleted by an automated retention job.

Financial records are retained for 7 years. Even after account deletion, we are required by HMRC and the Companies Act 2006 to keep records of completed transactions (booking references, amounts, organiser payouts) for 7 years. Those records are kept in an anonymised form (your personally-identifying fields are stripped at deletion; only the financial-event data remains). You cannot request earlier deletion of those records - but they are not used for any other purpose.

9.5 Customer support interactions

When you contact us via the contact form ([/contact](#)) or by

emailing support@dancerealm.co, the messages are stored as a support ticket linked to your account (or to the email address you wrote from, if you don't have an account):

- **What we keep:** the message body, the timestamps, your email address, and any reply we send.
- **Who can read it:** only the Privacy & Compliance Officer and a small designated support rota. Engineers reading production logs cannot see ticket bodies - the logger scrubs them before they reach our log store (src/lib/log-scrub.ts).
- **What we don't do:** support conversations are **not** reviewed by automated systems. They are **not** used to train AI (see §3a.1). They are **not** shared with third parties beyond the email-delivery sub-processor (Resend) which transmits them.
- **Retention:** 2 years after the ticket is closed (see §13), then permanently deleted.
- **Your rights:** support transcripts are included in your data export (§17). You can ask us to delete a specific ticket at any time.

9.6 Lawful basis

Transactional emails: **contract performance** (Art. 6(1)(b)). Marketing emails: **consent** (Art. 6(1)(a)) + PECR reg. 22. Financial-record retention: **legal obligation** (Art. 6(1)(c)) - HMRC + Companies Act 2006. Customer support interactions: **contract performance** + our **legitimate interest** (Art. 6(1)(f)) in operating an effective support function.

9.7 Module risk register & mitigations

Communications & GDPR-rights handling concentrates on delivery integrity, consent record-keeping, and the mechanics of subject-rights fulfilment.

A. Email / SMS delivery threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
Email delivery to wrong recipient	A typo in your registered email sends a booking confirmation to a stranger.	Email at signup must be verified by clicking a confirmation link before the account becomes fully usable. Email changes require re-verification of the new address before the change takes effect.

Lookalike-domain phishing impersonation	An attacker registers <i>thesbk-dance.com</i> or similar and emails users pretending to be us.	SPF / DKIM / DMARC fully aligned on <i>thesbkdance.com</i> with strict p=reject policy - this prevents senders from spoofing our domain. It does not stop attackers from registering visually-similar domains (e.g. <i>thesbk-dance.com</i>) and sending from those; the only mitigation we have for that is asking your mail provider to flag suspicious senders + monitoring publicly-registered lookalikes. Phishing reports go to abuse@thesbkdance.com.
Email open / click tracking without consent	Marketing emails contain hidden tracking pixels we did not disclose.	We do not use open-tracking pixels on transactional emails. Marketing emails (sent only to consenting users) include click-tracking on the unsubscribe link only, disclosed at consent time.

Email-preview leakage	A booking-confirmation preview pane on a shared device exposes ticket details.	Preview pane shows the event name and date only; the booking reference and QR code require opening the email. Sensitive information like full payment amount is in the body, not the preview.
SMS to wrong / recycled phone number	An OTP is sent to a number that has been recycled to a different person since signup.	Phone is verified at signup with a one-time OTP. Logged-in users prompt for re-verification on suspicious activity (new device from unknown country). UK phone numbers receive an inbound carrier-side recycle notification that we monitor for high-value accounts.
Hard-bounce list contamination	Repeated emails to a non-existent address damage our sender reputation, causing legitimate emails to land in spam.	Resend processes bounces and feeds them back via webhook; hard-bounced addresses are flagged in our DB and excluded from future sends until the user re-verifies. Bounce rate is monitored to keep it under 1%.

Marketing-email forwarding subscribing the forwarder	A user forwards a marketing email and the unsubscribe link, when clicked, accidentally unsubscribes them rather than the original recipient.	Unsubscribe tokens are bound to the recipient's email-address hash; the unsubscribe page asks for explicit confirmation before applying the change.
--	--	---

B. Marketing-consent integrity threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
Marketing email sent without opt-in	A user receives a newsletter despite never opting in.	The marketing-send query joins on the marketing_consent column with explicit WHERE consent = TRUE; row-level security in Supabase rejects sends to users without active consent. Each send logs the consent timestamp + version for audit.
Unsubscribe link broken	A user clicks Unsubscribe but the request fails silently.	Unsubscribe is a one-click HMAC-signed link backed by an idempotent endpoint. We log the timestamp of the unsubscribe action (required for compliance audit and to defend against subsequent "I never unsubscribed" disputes); we do not log it for marketing or analytics purposes. Failures alert on-call and the user's email is queued for manual processing within 5 working days.

Consent-record drift	Database state diverges from what the user actually consented to (e.g. soft-deleted accounts retain marketing flags).	Account deletion clears all marketing flags atomically. Daily reconciliation job verifies that every user receiving a marketing send has a current consent record.
Newsletter preference inheritance from old account	A user deletes and re-registers; the new account inherits stale marketing preferences.	Re-registration with a previously-deleted email triggers a fresh opt-in flow; consent state is not transferred from the deleted account. Each consent record is bound to the account ID, not the email.
SMS marketing without separate consent	A user opts in to email marketing but starts receiving SMS marketing too.	SMS marketing is on a separate consent flag from email marketing. We do not currently send SMS marketing at all; if introduced, the opt-in flow will be channel-specific.

C. Subject-rights / SAR threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
------	-----------------------	---------------------

SAR not actioned within 30 days	A request for your data takes longer than UK GDPR's one-month statutory deadline.	SARs to <i>support@dancerealm.co</i> are tracked with an SLA timer. Self-service data export is available from the user's profile so most requests are zero-touch. Complex requests may be extended by two months under Art. 12(3) UK GDPR with notice to the requester.
Identity-verification bypass on SAR	An attacker submits a SAR pretending to be you to obtain your data.	SAR responses are sent to the registered email of record, never to the requester's submitted address. Suspicious requests trigger a phone-OTP challenge to the registered phone number.
Data export including third-party PII	Your data export contains other users' emails (e.g. attendees of an event you organised).	Data export is scoped strictly to the requesting user's own data. Where third parties appear (e.g. ticket-transfer recipient), only the data the requester themselves provided or authored is included. Other users' PII is redacted.

Erasure incomplete (data lingering in backups)	You request deletion but your data remains in database backups for years.	Database backups are managed by our hosting provider (Supabase) and retained per the Point-In-Time-Recovery window of our current platform tier - typically between 7 and 30 days. An erasure request deletes from the live database immediately; the data falls out of backups when the rolling PITR window passes (i.e. at most by the end of that window). Backup-side rehydration of a deleted account is procedurally blocked: any restore from backup goes through the same account-deletion job, which re-applies the user's erasure decision before the restored data becomes queryable. Backups are encrypted at rest by the provider; key rotation is on the provider's schedule (publicly documented in their security pages).
---	--	--

SAR data leaked via wrong-recipient send	Your data export accidentally goes to a different user.	Export downloads are served via signed URLs scoped to the requester's authenticated session. We never email exports as attachments to a manually-entered address.
SAR data export DOS	An attacker submits hundreds of SARs to consume our admin time.	Self-service export removes the per-request admin cost. Manifestly excessive requests can be refused or charged a reasonable fee under Art. 12(5) UK GDPR.

D. Erasure & cross-jurisdictional threats

RISK	WHAT IT MEANS FOR YOU	MITIGATION IN PLACE
Cross-jurisdictional erasure conflicts	Data on US sub-processors is harder to erase than data in our UK / EU systems.	Our DPA with each sub-processor includes a contractual erasure-on-instruction clause. Most sub-processors expose self-service deletion APIs (Resend, Stripe, Twilio); we use them as part of the account-deletion job.
Stripe-retained financial data after erasure	You request deletion but Stripe still holds 7 years of payment history.	Disclosed in §13: Stripe independently retains payment data for financial-regulation reasons. Users are directed to Stripe's privacy contact for direct deletion requests where legally possible.

Account-recovery email reach-out	After a deletion, we contact the user via email to confirm or to upsell.	Account deletion is final after the 30-day grace period. We do not re-engage deleted users via marketing or recovery campaigns. The only post-deletion email is a final confirmation.
----------------------------------	--	---

Risk registers across all six modules above (§4.6, §5.5, §6.7, §7.5, §8.5, §9.7) are reviewed during the DPIA review cycle (§18) and exposed in the internal DPIA at docs/dpia/2026-q2.md with likelihood × severity scoring. The public versions list the user-facing mitigation only. If you spot a risk we've missed, please email support@dancerealm.co.

PART 3 - CROSS-CUTTING COMPLIANCE

10. Lawful basis matrix

The complete set of lawful bases applied across the modules in Part 2:

ACTIVITY	LAWFUL BASIS	MODULE

11. Information sharing & sub-processors

We share your personal data with the following third-party service providers acting under written processing agreements aligned with Article 28 UK GDPR. Where providers are located outside the UK, transfers are protected by an instrument permitted under UK GDPR Article 46 - see §12.

PROVIDER	COUNTRY	PURPOSE	DATA SHARED	PRIVACY NOTICE
Supabase Inc.	EU-West (DB) / USA (corp)	Database hosting & user authentication	All account data, bookings, events	link

Stripe Payments UK Ltd.	UK (with US sub-processors via Stripe's SCCs)	Payment processing, payouts, fraud prevention. Payment methods enabled today: card (Visa / Mastercard / Amex), Apple Pay and Google Pay. BNPL methods (Klarna, Afterpay/ Clearpay) are NOT currently enabled; if added in future, the lender will be disclosed in this row before being presented to users.	Payment data, organiser identity & banking, IP. Apple Pay / Google Pay flows additionally use a device-bound wallet token routed via Apple / Google — that token never reaches our servers.	link
Resend, Inc.	USA	Transactional & marketing email delivery	Email address, name, email content	link
Twilio Inc.	USA	SMS for phone verification & admin MFA	Phone number, OTP message content	link

Google LLC	USA	OAuth sign-in & event location maps	Email, name, profile pic (OAuth); IP & queries (Maps, only after consent)	link
Cloudflare Inc.	USA	Bot mitigation in front of Supabase	IP address, request metadata	link
Cookiebot / Usercentrics A/S	Denmark (parent: Germany)	Consent-record management	Consent choice + IP for region detection	link
Intuition Machines (hCaptcha)	USA	Bot challenge during signup/login (Supabase Auth)	IP, browser environment for the duration of the challenge	link
Vercel Inc.	USA	Application hosting (compute & CDN). Not used for analytics.	IP address, request metadata (server logs)	link

A live machine-readable summary is exposed at </api/transparency> with a human-readable counterpart at </transparency>.

12. International transfers

Several of our sub-processors are located outside the UK. When your personal data is transferred internationally, we rely on:

- UK adequacy regulations and “data bridge” instruments designated under section 17A of the 2026 Act (including the UK-US Data Bridge for transfers to certified US importers);
- the UK International Data Transfer Addendum to the EU Standard Contractual Clauses (IDTA), where the data bridge does not apply;
- EEA adequacy decisions (e.g. Denmark);
- supplementary technical and organisational measures (TLS in transit, encryption at rest, contractual access controls).

You may request a copy of the safeguards we rely on for any specific transfer by contacting our Privacy & Compliance Officer.

13. Data retention

We retain your personal data only as long as necessary for the purpose it was

collected, in accordance with UK GDPR Article 5(1)(e). Specific retention periods:

DATA	RETENTION PERIOD	THEN
Active user account	While the account is active	-
Inactive account (no login for 3 years)	3 years + 30-day warning email	Hard delete (subject to legal retention rows below)
Deleted account (user-initiated)	30-day grace period for recovery	Hard delete by /api/cron/purge-deleted-accounts
Booking & payment records	7 years (HMRC + Companies Act 2006)	Anonymised: PII stripped, financial event data retained
Pending ticket transfers	Until claimed, then 30 days for audit	Recipient email purged
Support tickets	2 years	Permanently deleted
Authentication event logs	12-month rolling window	Deleted
Cookie consent record	1 year (or until you click "Cookie Settings")	Banner re-prompts
Email send logs (Resend)	90 days	Deleted by Resend
SMS send logs (Twilio)	12 months	Deleted by Twilio

Third-party retention. Stripe independently retains payment and payout history per financial-regulation requirements; this data cannot be deleted through our platform. Contact privacy@stripe.com or visit the [Stripe privacy centre](#) to request deletion of records held directly by Stripe.

14. Data security

We implement appropriate technical and organisational security measures aligned with the ISO/IEC 27001:2022 framework. External certification has not yet been engaged.

- Encryption of data in transit (TLS 1.2+) and at rest (Supabase managed encryption + bcrypt for passwords).
- HttpOnly & Secure cookies for session tokens.
- Role-based access controls and per-row authorisation (Supabase RLS policies).
- CSRF protection (double-submit token pattern) on all state-changing requests.
- Cloudflare bot mitigation in front of our backend.
- Audit logs of administrative actions; rate-limiting of authentication endpoints.

- Regular dependency & vulnerability scans.

15. Data breach notification

In the event of a personal-data breach that is likely to result in a risk to your rights and freedoms, we will:

- **Notify the UK ICO within 72 hours** of becoming aware of the breach (Article 33 UK GDPR);
- Notify affected data subjects without undue delay where the breach is likely to result in a *high* risk (Article 34 UK GDPR), via the email on your account;
- Maintain an internal breach register (Article 33(5));
- Engage forensic investigation support where necessary.

Breach response is owned by our Privacy & Compliance Officer (support@dancerealm.co).

16. Cookies and tracking

The full inventory, retention periods and lawful bases are documented in our [Cookie Policy](#). Highlights:

- Strictly Necessary cookies for auth, CSRF, paywall state, bot mitigation, consent record. Cannot be disabled.
- Functional + Marketing cookies set by Google Maps when you grant Functional consent. Decline → maps become a placeholder.
- Payment & fraud cookies set by Stripe on checkout / subscription pages.
- **No analytics cookies** are currently set.
- Global Privacy Control (GPC) signal honoured as a refusal of non-essential cookies.

17. Subject Access Request (SAR) process

To make a Subject Access Request:

1. Email support@dancerealm.co with the subject line "Subject Access Request".
2. We may ask you to confirm your identity from the email registered on your account.
3. We will respond within **one month** of receipt (Art. 12(3) UK GDPR), extendable by two months for complex requests.
4. Where possible we provide your data in a portable JSON format (Art. 20 UK GDPR). Non-portable items (logs, support transcripts) come as PDF.

Your export specifically includes: account profile fields; bookings & ticket records; RSVPs and saved events; reviews you have left and any received on your events; messages you have sent through our support channel; consent-record history (cookies, marketing); and the last 12 months of authentication event logs (sign-in time, IP, user agent, sign-in method). Auth logs older than 12 months are not retained and so are not exportable.

5. No charge for the first request in any 12-month period; manifestly unfounded or excessive requests may attract a reasonable

administrative fee or be refused.

Self-service: you can export your data via the “Export my data” option in your profile settings, and you can delete your account from the same screen.

18. DPIA & ROPA

We maintain an internal Data Protection Impact Assessment (Article 35 UK GDPR + section 65 of the 2026 Act) covering every data flow described in Part 2. The DPIA is owned by our Privacy & Compliance Officer and was last reviewed on 7 May 2026; next due 7 May 2027. The processing was assessed as **low residual risk** after mitigations.

We also maintain Records of Processing Activities (Article 30 UK GDPR + Schedule 6 of the 2026 Act). A redacted summary of either document is available on written request to support@dancerealm.co.

19. Children

The Service is not directed at children under 13. Account creation requires age 16+; users aged 13–17 require guardian agreement to be bound by the Terms of Service. Paid features (Subscription, AutoPay, ticket purchases) are restricted to users aged 18+ by our payment processor.

We do not show advertising and do not run analytics, so the heightened risks the ICO’s Age-Appropriate Design Code targets do not arise on the Service.

20. Accessibility

We aim to meet WCAG 2.2 AA. We have not yet commissioned an external accessibility audit – this is a self- attestation. If you encounter a barrier when exercising any privacy right, contact support@dancerealm.co and we will resolve it without requiring further consent.

21. Automated decisions & profiling

We do not currently make decisions producing legal effects on you, or similarly significantly affecting you, based solely on automated processing (Article 22 UK GDPR). The Service uses algorithmic ranking for event recommendations and trending rails, but this affects the order of public listings only – it does not deny access, alter pricing, or change any of your rights.

Stripe Radar performs automated fraud risk scoring on payment attempts (see §6.4). You can ask Stripe to review any decline via their [privacy contact](#).

22. Third-party links

Our Service may contain links to third-party websites or services that are not operated by us, including event organiser websites and social-media profiles. We have no control over their content, privacy policies or practices. Review the privacy policy of every site you visit.

23. Changes to this Policy

When we make material changes (a new sub-processor, a new lawful basis, a new category of data, a new module) we will publish a new version, add a row to §26 below, display an in-Service notice on your next visit, and where the change requires fresh consent re-prompt you via the consent banner.

24. Governing law

This Privacy Policy is governed by the laws of England and Wales, including the UK Data (Use and Access) Act 2026, the UK General Data Protection Regulation (UK GDPR) and the Data Protection Act 2018.

25. Contact & complaints

For questions about this Privacy Policy or to exercise any right:

Inteleforge Limited (trading as The SBK Dance)

Privacy & Compliance Officer: support@dancerealm.co

Website: www.inteleforge.co.uk

You have the right to lodge a complaint with the UK Information

Commissioner's Office **at any time** - you do not have to wait for our response.

Information Commissioner's Office (ICO)

Wycliffe House, Water Lane, Wilmslow, Cheshire, SK9 5AF

Website: ico.org.uk

Helpline: 0303 123 1113

Under the Complaints Handling Duty introduced by the 2026 Act, we will acknowledge complaints within 5 working days and provide a substantive reply within 30 days.

26. Sanctions, appeals & complaints SLA

The Service moderates user-generated content (Event listings, Teacher profiles, reviews, profile photos) and may suspend accounts that breach our acceptable-use rules. The procedure below applies to every moderation action and every user complaint, in line with the UK Online Safety Act 2023 and the Complaints Handling Duty introduced by the UK Data (Use and Access) Act 2026 (active from June 2026).

26.1 Reporting flagged content or behaviour

Any visitor or signed-in user can flag a piece of content (event listing, review, profile, image) or report a user for breach of the acceptable-use rules:

- Click the *Report* link on the relevant page;
- Or email support@dancerealm.co with the URL and a short description of the concern;
- Or, for content covered by the Defamation Act 2013 §5 notice procedure, email the same address with the specific notice information that section requires.

26.2 Service-level commitments

STAGE	OUR COMMITMENT	STATUTORY BASIS
Acknowledgement of report or complaint	Within 5 working days	2026 Act Complaints Handling Duty
Substantive reply (decision, action taken or not, reasons)	Within 30 calendar days	2026 Act Complaints Handling Duty
Imminent-harm exception (CSAM, threats of violence, doxx, etc.)	Action within 24 hours	Online Safety Act 2023 priority illegal content duties

Appeal of a content removal or account suspension	Reviewed within 14 calendar days	Online Safety Act 2023 + Art. 22 UK GDPR (right not to be subject to solely-automated decisions)
---	---	--

26.3 What happens when content is removed or an account is suspended

1. **Notification.** The affected user receives an email at the address registered on their account, citing the specific content removed or the specific account action taken, the rule breached, and the appeal route described below.
2. **Preservation.** Removed content is quarantined for 30 days before final deletion so it can be restored on a successful appeal.
3. **Pending refunds.** If a Teacher / Organizer is suspended with active paid Events, attendees of those Events are refunded automatically; refunds settle to the original payment method via Stripe within 5–10 working days. Where a refund cannot complete (closed card etc.), the user is contacted by email to arrange an alternative.

26.4 Appeal process

You have the right to appeal any moderation decision. To appeal:

1. Reply to the moderation-decision email within **30 calendar days** of receipt, OR email support@dancerealm.co with the subject line "Appeal".
2. State the moderation reference number, the action you are appealing, and the grounds for your appeal (factual error, misclassification, change of circumstances, etc.).
3. The appeal is reviewed within **14 calendar days**. Where staffing permits, a different reviewer to the one who made the original decision will conduct the review; otherwise the original decider re-examines the evidence with any new submission you provide, and a senior member of staff signs off the outcome. If the appeal is upheld, the action is reversed and the content / account is restored from the 30-day quarantine.
4. If the appeal is rejected, the response will explain why and provide details of how to escalate to the UK Information Commissioner's Office (for data- protection grounds) or the Online Safety Act ombudsman (for content-removal grounds).

26.5 Specific safeguards for automated decisions

Where any element of a moderation or anti-fraud decision is taken by an automated system (e.g. Stripe Radar declines a transaction; an automated heuristic flags a referral cohort), Article 22 UK GDPR applies. You have the right to:

- Request human review of any automated decision affecting your account or transaction;
- Contest the decision;
- Receive an explanation of the logic involved (to the extent we can

- disclose it without compromising the anti-fraud system);
- Have a meaningful opportunity to express your view to a person empowered to overrule the automated outcome.

Use the same appeal route described in §26.4 to invoke these rights.

26.6 ICO / regulator escalation at any time

You do not have to exhaust our internal procedure before contacting a regulator. You may contact the UK ICO (ico.org.uk) at any time on data-protection grounds, or Ofcom (ofcom.org.uk) on Online-Safety-Act grounds. We encourage you to raise the issue with us first so we can put it right, but you retain that right unconditionally.

27. Version history

VERSION	DATE	MATERIAL CHANGES
2026-04-v1	16 April 2026	Initial version.